NIST Cybersecurity Framework 2.0: Comprehensive Study Notes

For Cybersecurity Learners | Beginner to Intermediate Level

Table of Contents

1. Introduction to NIST CSF 2.0
2. Historical Context
3. CSF 2.0 Core Components
4. The Six Functions Explained
5. CSF Profiles and Tiers
6. Practical Applications
7. Key Differences: CSF 1.1 vs CSF 2.0
8. Learning Tasks & Assignments
9. References & Resources

---

1. Introduction to NIST CSF 2.0

What is the NIST Cybersecurity Framework?

The **NIST Cybersecurity Framework (CSF) 2.0** is a comprehensive set of guidelines and best practices developed by the U.S. National Institute of Standards and Technology to help organizations of **all sizes and sectors** understand, assess, prioritize, and manage cybersecurity risks.

Released: February 26, 2024 (NIST CSWP 29)

Key Characteristics of CSF 2.0

Characteristic	Description
Flexibility	Works for organizations of any size, sector, or maturity level
Non-Prescriptive	Provides outcomes, not rigid rules or exact methods
Sector-Neutral	Applicable to industry, government, academia, and nonprofits
Technology-Neutral	Works across IT, IoT, OT, cloud, mobile, and AI systems
Governance-Focused	Emphasizes organizational risk management strategy
Supply Chain Aware	Includes cybersecurity supply chain risk management

Who Should Use CSF 2.0?

- **Primary Audience:** Leaders developing and leading cybersecurity programs
- **Secondary Users:** Executives, board members, technology professionals, risk managers, compliance officers, auditors
- **Stakeholders:** Policy makers, associations, regulators, business partners

---

2. Historical Context

Evolution of NIST CSF

Version	Release Date	Key Focus	Major Change
CSF 1.0	February 2014	Critical infrastructure cybersecurity	Initial framework creation
CSF 1.1	April 2018	Broader organizational adoption	Supply chain risk basics
CSF 2.0	February 2024	Comprehensive governance & supply chains	Added GOVERN function

Why CSF 2.0 Was Needed

The cybersecurity landscape evolved significantly since 2018:

- **Advanced Threats:** Ransomware, supply chain attacks, and nation-state threats increased
- **Governance Gap:** Organizations needed better risk governance frameworks
- **Supply Chain Risks:** Third-party breaches became critical threat vectors
- **Integration:** Better alignment with enterprise risk management (ERM) needed
- **Broader Adoption:** Small organizations and nonprofits required more accessible guidance

---

3. CSF 2.0 Core Components

The CSF Core Structure

The CSF Core is a taxonomy of high-level cybersecurity outcomes organized in a hierarchy:

```
CSF Core
├── Functions (6 categories)
│   ├── Categories (related outcomes)
│   │   └── Subcategories (specific outcomes)
```

Core Purpose

The CSF Core provides **sector, country, and technology-neutral** outcomes that:

- Help any organization manage cybersecurity risks
- Enable communication across technical and executive levels
- Support prioritization and resource allocation
- Guide continuous improvement efforts

Key Principle

> The CSF Core is **not a checklist**. Organizations implement outcomes differently based on their unique mission, risks, resources, and context.

---

4. The Six Functions Explained

Overview: The CSF Functions Wheel

CSF 2.0 introduced a critical new function—**GOVERN**—placing it at the center, recognizing that effective cybersecurity requires organizational strategy and oversight.

All six functions work together in a continuous cycle.

Function 1: GOVERN (GV)

Definition: The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored.

Purpose: Provides the foundation for all other functions by establishing organizational context and governance.

Key Governance Areas:

1. **Organizational Context**
   - Understanding mission and objectives
   - Identifying stakeholder expectations
   - Assessing risk appetite and tolerance

    - Evaluating regulatory and legal requirements
2. **Cybersecurity Strategy**
    - Developing risk management strategy
    - Setting cybersecurity objectives
    - Defining supply chain risk management approach
    - Establishing policies and procedures
3. **Roles and Responsibilities**
    - Assigning cybersecurity leadership
    - Defining authorities and accountability
    - Establishing reporting structures
    - Setting performance expectations
4. **Oversight**
    - Monitoring cybersecurity performance
    - Assessing compliance with policies
    - Reviewing strategic direction
    - Ensuring resource allocation

GOVERN Outcomes Include:

- Risk management strategy is documented and communicated
- Cybersecurity policies are established and reviewed
- Supply chain cybersecurity is managed
- Cybersecurity roles and responsibilities are defined
- Executive oversight is established

Real-World Example - University IT Department

```
SCENARIO: A university's GOVERN function activities include:
- CIO establishes cybersecurity strategy aligned with academic mission
- Board approves cybersecurity budget and policy
- IT leadership defines roles (Chief Security Officer, system administrators)
- Supply chain requirements set for cloud service providers
- Annual risk assessment reviews cybersecurity gaps
- Students, faculty, and staff trained on security policies
```

Function 2: IDENTIFY (ID)

Definition: The organization's current cybersecurity risks are understood.

Purpose: Enable organizations to know what they have and what could go wrong—essential before you can protect, detect, or respond.

Key IDENTIFY Activities:

1. **Asset Management**
    - Inventory all IT and OT assets (hardware, software, data)

  - Document systems and applications
  - Track device lifecycles
  - Maintain configuration records
2. **Risk Assessment**
  - Identify threats and vulnerabilities
  - Analyze potential business impacts
  - Prioritize risks by severity
  - Evaluate threat intelligence
3. **Improvement Identification**
  - Document policy and procedure gaps
  - Identify control weaknesses
  - Note training and awareness needs
  - List technical improvements required

Critical Questions for IDENTIFY:

- What IT and data assets do we have?
- Who has access to critical systems?
- What data is sensitive or valuable?
- What threats could we face?
- Where are our security gaps?
- What could go wrong, and what's the impact?

Real-World Example - E-Commerce Company

```
IDENTIFY Activities:
✓ Catalog: 500+ servers, 150+ applications, customer database
✓ Risk Assessment: PCI DSS compliance requirements
✓ Vulnerabilities: Outdated payment processing library identified
✓ Impact: Data breach could expose 10M customer records → Regulatory fines
✓ Gaps: Insufficient backup procedures for database
✓ Result: Prioritize upgrading payment system and backup infrastructure
```

Function 3: PROTECT (PR)

Definition: Safeguards to manage the organization's cybersecurity risks are used.

Purpose: Implement preventive controls and defenses to reduce likelihood and impact of cyber incidents.

Key PROTECT Areas:

1. **Access Control & Identity Management**
  - Multi-factor authentication (MFA)
  - Role-based access control (RBAC)
  - Privileged access management (PAM)

- Single sign-on (SSO)
- Regular access reviews

2. **Data Security**
   - Encryption at rest and in transit
   - Data classification schemes
   - Data loss prevention (DLP)
   - Secure disposal procedures
   - Privacy controls
3. **Platform Security**
   - Patch management
   - Secure configuration baselines
   - Vulnerability management
   - Secure software development
   - Hardware security
4. **Awareness and Training**
   - User security awareness programs
   - Phishing simulation training
   - Incident response training
   - Security culture development
   - Onboarding/offboarding procedures
5. **Infrastructure Resilience**
   - Backup and recovery systems
   - Redundancy and failover
   - Incident response planning
   - Business continuity planning
   - Disaster recovery procedures

PROTECT Controls - Quick Reference:

Control Category	Examples
Authentication	Passwords, MFA, biometrics, smart cards
Authorization	RBAC, ACLs, attribute-based access control
Encryption	TLS/SSL, AES, end-to-end encryption
Updates	Patch management, version control
Monitoring	Logging, auditing, configuration monitoring
Backup	Incremental/full backups, offsite storage, 3-2-1 rule

Real-World Example - Healthcare Provider

```
PROTECT Measures:
✓ MFA on all staff accounts accessing patient data (HIPAA requirement)
✓ Encryption of all databases containing protected health information (PHI)
✓ Annual HIPAA security training for all employees
```

```
✓ Patch management system updates Windows/Linux monthly
✓ Daily encrypted backups stored offsite in separate facility
✓ Role-based access: Doctors see patient data, Billing only sees insurance
✓ DLP tools prevent USB copying of patient records
✓ VPN required for remote access to hospital systems
```

Function 4: DETECT (DE)

Definition: Possible cybersecurity attacks and compromises are found and analyzed.

Purpose: Enable timely discovery of security incidents so response can minimize damage.

Key DETECT Activities:

1. **Monitoring and Analysis**
   - System and application logging
   - Network traffic analysis
   - Endpoint monitoring
   - User behavior analytics
   - Log aggregation and centralization
2. **Anomaly Detection**
   - Intrusion detection systems (IDS)
   - Suspicious login detection
   - Unusual data access patterns
   - Malware detection
   - DDoS detection
3. **Incident Investigation**
   - Forensic analysis
   - Alert investigation and triage
   - Root cause analysis
   - Indicator of compromise (IOC) identification
   - Impact assessment

DETECT Technologies & Tools:

Technology	Purpose
SIEM (Security Information & Event Mgmt)	Centralize and analyze logs
IDS/IPS (Intrusion Detection/Prevention)	Detect and block suspicious network traffic
EDR (Endpoint Detection & Response)	Monitor endpoints for threats
UEBA (User Behavior Analytics)	Detect unusual user activities
Threat Intelligence	Identify known threats and IOCs

Real-World Example - Financial Services Company

```
DETECT Implementation:
✓ SIEM ingests logs from 200+ systems into central platform
✓ Alert triggered: Unusual after-hours login from new country
✓ EDR agent detects process spawn behavior matching ransomware
✓ Analyst investigates: Employee's credentials compromised
✓ IDS shows lateral movement attempts to financial systems
✓ Response initiated: Account disabled, systems isolated
✓ Impact assessment: No sensitive data exfiltrated (early detection)
```

Function 5: RESPOND (RS)

Definition: Actions regarding a detected cybersecurity incident are taken.

Purpose: Enable quick, coordinated action to contain incident effects and minimize damage.

Key RESPOND Activities:

1. **Incident Management**
   - Incident classification and prioritization
   - Incident commander assignment
   - Response team mobilization
   - Communication protocols
   - Status tracking and updates
2. **Analysis & Investigation**
   - Determine incident scope and impact
   - Identify affected systems/data
   - Preserve evidence for forensics
   - Document timeline of events
   - Analyze attacker methods
3. **Mitigation & Containment**
   - Isolate affected systems (network segmentation)
   - Disable compromised accounts
   - Remove malware/backdoors
   - Patch vulnerabilities
   - Reset credentials
4. **Communication & Reporting**
   - Internal notifications to leadership
   - External notifications to customers (if required)
   - Regulatory reporting (if required)
   - Law enforcement notification (if criminal)
   - Post-incident reports

Incident Response Lifecycle:

```
1. Preparation → 2. Detection & Analysis → 3. Containment
    ↑                                                ↓
4. Eradication ← 5. Recovery ← 6. Post-Incident Activities
```

Real-World Example - Retail Company Data Breach

```
RESPOND Timeline:
T+0:00 - Alert: SIEM detects unauthorized database access
T+0:15 - Incident Commander convenes response team
T+0:30 - Initial assessment: 5 million customer records at risk
T+1:00 - Containment: Database access revoked, system isolated
T+2:00 - Analysis: SQL injection vulnerability identified
T+4:00 - Mitigation: Vulnerability patched, all backups restored
T+6:00 - Notification: Customer service team prepares notifications
T+24:00 - Reporting: Incident report filed with state attorney general
```

Function 6: RECOVER (RC)

Definition: Assets and operations affected by a cybersecurity incident are restored.

Purpose: Enable timely restoration to normal operations and build organizational resilience.

Key RECOVER Activities:

1. **Recovery Planning & Preparation**
   - Recovery time objectives (RTO)
   - Recovery point objectives (RPO)
   - Backup schedules and testing
   - Recovery procedures documentation
   - Redundant systems deployment
2. **System Restoration**
   - Restore from clean backups
   - Rebuild compromised systems
   - Restore data and applications
   - Verify system integrity
   - Performance testing
3. **Operational Continuity**
   - Restore business processes
   - Restore data access
   - Resume normal operations
   - Monitor for re-infection
   - Maintain incident logging
4. **Post-Incident Improvement**
   - Root cause analysis

- Identify preventive actions
- Update security controls
- Improve detection capabilities
- Update incident response procedures
- Share lessons learned

Recovery Priorities:

1. **Mission-Critical Systems** (Internet, email, core business)
2. **Customer-Facing Systems** (Websites, applications)
3. **Data Systems** (Databases, file servers)
4. **Support Systems** (HR, finance, IT)
5. **Secondary Systems** (Development, testing)

Real-World Example - Manufacturing Company

```
RECOVER After Ransomware Attack:

Phase 1 - Immediate (Hours)
✓ Boot production control systems from clean backups
✓ Verify no malware remains using clean-room scanning
✓ Test critical manufacturing processes

Phase 2 - Short-term (Days)
✓ Restore all databases to pre-attack state
✓ Verify data integrity and consistency
✓ Restore order management system
✓ Resume customer communications

Phase 3 - Long-term (Weeks)
✓ Analyze root cause: Outdated VPN security
✓ Implementation: Upgrade VPN to modern standards
✓ Deploy network segmentation (OT vs IT)
✓ Implement EDR on all critical systems
✓ Provide incident lessons-learned training

RTO: 48 hours | RPO: 4 hours | Total recovery: 2 weeks
```

---

5. CSF Profiles and Tiers

CSF Organizational Profiles

Definition: An Organizational Profile describes an organization's **current and/or target cybersecurity posture** in terms of the CSF Core's outcomes.

Two Types of Profiles:

1. **Current Profile**
   - Describes what the organization **currently** implements
   - Documents existing security controls and practices
   - Identifies current maturity level
   - Provides baseline for improvement planning
2. **Target Profile**
   - Describes desired **future** state
   - Based on organizational objectives and risks
   - Aligned with business strategy
   - Informs resource allocation and planning

Creating an Organizational Profile - 5 Steps:

```
Step 1: SCOPE
├─ Define what the profile covers
├─ Document assumptions and constraints
└─ Consider different profiles for different systems/divisions

Step 2: GATHER INFORMATION
├─ Collect organizational policies
├─ Review risk assessments
├─ Document current controls
├─ Identify requirements and standards

Step 3: CREATE PROFILE
├─ Map current state to CSF outcomes
├─ Assess maturity level
├─ Create target state objectives
└─ Prioritize desired outcomes

Step 4: ANALYZE GAPS
├─ Compare Current vs. Target Profile
├─ Identify missing controls
├─ Prioritize high-impact improvements
└─ Create action plan (POA&M)

Step 5: IMPLEMENT & ITERATE
├─ Execute action plan
├─ Monitor progress
├─ Update profiles regularly
└─ Repeat for continuous improvement
```

CSF Tiers

Definition: Tiers characterize the **rigor and maturity** of an organization's cybersecurity risk governance and management practices.

Four Tiers Explained:

Tier	Name	Characteristics	Governance Style
Tier 1	Partial	Informal, ad-hoc, reactive	Minimal governance, reactive responses
Tier 2	Risk Informed	Process-aware, some planning	Risk-informed processes established
Tier 3	Repeatable	Standardized, consistent processes	Formal processes, regular monitoring
Tier 4	Adaptive	Continuous improvement, agile	Risk-driven, continuously evolving

Tier 1: Partial

Characteristics: - Limited cybersecurity awareness - Reactive responses to incidents - Few documented procedures - Minimal resource allocation - Ad-hoc risk management

Example Organization:

```
Small startup (10 employees) with:
- No dedicated security staff
- Basic antivirus on computers
- Weak password policies
- No formal incident response plan
- Minimal documentation
```

Tier 2: Risk Informed

Characteristics: - Risk management strategy exists - Some processes documented - Partial awareness programs - Resources allocated for security - Beginning to standardize controls

Example Organization:

```
Mid-size company (100 employees) with:
- Security manager hired
- Basic written policies
- Annual security training
- Patch management program
- Incident reporting procedures
- Basic log monitoring
```

Tier 3: Repeatable

Characteristics: - Standardized security processes - Regular assessments and testing - Documented procedures - Security training programs - Clear roles and responsibilities - Continuous monitoring

Example Organization:

```
Large company (500+ employees) with:
- Dedicated security team
- ISMS (ISO 27001) certified
- Annual penetration testing
- Quarterly security assessments
- Formal incident response team
- 24/7 SOC monitoring
- Regular training and awareness
```

Tier 4: Adaptive

Characteristics: - Continuous improvement culture - Automated threat detection - Rapid response capabilities - Threat intelligence integration - Proactive security measures - Advanced analytics and AI - Industry leadership

Example Organization:

```
Enterprise/Financial Institution (10,000+ employees) with:
- Advanced SOC with threat hunting
- AI-powered anomaly detection
- Automated incident response
- Custom threat intelligence
- Red team/blue team exercises
- Zero-trust architecture
- Continuous compliance monitoring
- Proactive vulnerability research
```

Tier Progression Guide:

When to Progress to Higher Tiers: - Higher risk tolerance requires higher tier - Regulatory mandates may require higher tier - Cost-benefit analysis justifies investment - Organizational maturity supports progression - Resource availability enables higher tier

Tier Progression NOT Required: - CSF can be used effectively at any tier - Small organizations successfully use Tier 1-2 - Some organizations intentionally choose specific tier - Tier is about governance rigor, not security effectiveness

Profile & Tier Example - Hospital

```
HOSPITAL CYBERSECURITY PROFILE & TIER

Organization: 200-bed regional hospital
Current Tier: Tier 2 (Risk Informed)
Target Tier: Tier 3 (Repeatable)

Current Profile (Tier 2):
├─ GOVERN: Security policies exist, board oversight minimal
├─ IDENTIFY: Asset inventory incomplete, annual risk assessment
├─ PROTECT: Antivirus, basic encryption, annual training
├─ DETECT: Basic log collection, no SOC
├─ RESPOND: Incident procedures exist, team still forming
```

```
└─ RECOVER: Backups exist, recovery procedures informal

Target Profile (Tier 3) - 2-year plan:
├─ GOVERN: CIO reports to CEO, formal governance committee, formal supply
chain risk program
├─ IDENTIFY: Complete asset inventory, quarterly risk assessment, annual
penetration testing
├─ PROTECT: MFA on all systems, encryption standard, quarterly training,
policy updates
├─ DETECT: SIEM implementation, 24/5 SOC coverage, threat intelligence feeds
├─ RESPOND: Formal incident response team, response procedures, quarterly
drills
└─ RECOVER: Annual backup testing, RTO/RPO defined, documented procedures

Investment: $2M over 2 years
Expected Benefits: Reduced breach risk, faster incident response, better
compliance (HIPAA)
```

---

6. Practical Applications

How Different Organizations Use CSF 2.0

1. Small Business (50 employees)

Challenge: Limited budget and staff

CSF Application: - Tier 1-2 focus on IDENTIFY and PROTECT - Use community profiles for industry - Focus on high-risk areas first - Leverage managed security service providers (MSSP) - Simple Organizational Profile to guide investment

Implementation:

```
Year 1 Focus:
- Identify critical assets and data
- Implement basic protections (MFA, patches, backups)
- Establish basic incident response
- Annual training

Year 2 Expansion:
- Formalize GOVERN function
- Implement DETECT capabilities (SIEM)
- Regular risk assessments
- Move toward Tier 2
```

2. Medium Enterprise (1,000 employees)

Challenge: Balancing security with business growth

CSF Application: - Tier 2-3 across all functions - Custom Organizational Profile per business unit - Supply chain risk management program - Formal governance structure - Quarterly assessments and updates

Implementation:

```
Governance:
- CISO reports to CRO
- Quarterly risk committee meetings
- Formal cybersecurity strategy

Operations:
- Dedicated security team by function (6-10 FTE)
- Annual security assessments
- Monthly metrics dashboard for executives
- Supplier security assessments

Continuous Improvement:
- Red team exercises
- Threat modeling sessions
- Lessons learned from incidents
```

3. Large Financial Institution

Challenge: Complex environment, high regulatory requirements, sophisticated threats

CSF Application: - Tier 3-4 across all functions - Multiple specialized Organizational Profiles - Advanced supply chain risk program - Continuous threat intelligence integration - Board-level cybersecurity governance

Implementation:

```
Enterprise Governance:
- Chief Information Security Officer (CISO)
- Dedicated Cybersecurity Office (100+ FTE)
- Board of Directors Cyber Committee
- Regular CRO/CISO reports to executive leadership

Technology Stack:
- Multiple SOCs (24/7/365)
- Advanced threat detection and hunting
- Automated incident response
- AI-powered risk analytics
- Purple team exercises (red vs blue)

Supply Chain:
- Formal vendor risk management program
- Regular security assessments of partners
- Contractual security requirements
- Incident notification requirements
```

```
Compliance:
- Real-time compliance monitoring
- Quarterly assessments
- External audits and penetration tests
- Regulatory reporting automation
```

---

7. Key Differences: CSF 1.1 vs CSF 2.0

Major Changes in Version 2.0

Area	CSF 1.1	CSF 2.0	Impact
Functions	5 Functions	6 Functions (added GOVERN)	Emphasizes governance importance
Governance	Limited guidance	GOVERN function with detailed outcomes	Stronger org alignment required
Supply Chain	Basic mention	Dedicated GOVERN outcomes	Formal supply chain risk program
Online Resources	Minimal	Extensive materials	More accessible to all sizes
Profiles & Tiers	Described	Significantly expanded	More practical guidance
Privacy Integration	Separate	Integrated throughout	Better relationship clarity
ERM Integration	Limited	Major emphasis	Cybersecurity within enterprise risk

The New GOVERN Function

Why Added: - Increasing recognition that cybersecurity is enterprise-level risk - Need for better board-level oversight - Supply chain threats require strategic response - Organizations need governance framework for other functions

What It Covers: - Cybersecurity risk management strategy - Organizational context and objectives - Stakeholder expectations - Supply chain risk management - Roles, responsibilities, and authorities - Policies and oversight

---

8. Learning Tasks & Assignments

Task 1: Create a Personal IDENTIFY Profile (Beginner)

Objective: Understand the IDENTIFY function by analyzing your personal digital life

Instructions:

1. **Personal Asset Inventory:**
   - List all your devices (laptop, phone, tablet, smartwatch, etc.)
   - Document accounts you use (email, cloud storage, social media, banking, etc.)
   - Identify sensitive data you store (photos, documents, financial info, health records)
2. **Risk Assessment:**
   - For each asset, identify potential threats
   - Estimate impact of each threat (scale 1-10)
   - Determine likelihood
3. **Current Controls Inventory:**
   - What protections do you currently have?
   - Are passwords strong and unique?
   - Which accounts use 2FA?
   - What data is backed up?
   - How current is your software?
4. **Report (500-700 words):**
   - Summary of your digital assets
   - Top 3 risks identified
   - Current security controls strengths
   - Areas for improvement

Task 2: Design a PROTECT Strategy for a Small Business (Intermediate)

Objective: Apply PROTECT concepts to a realistic scenario

Scenario:

```
30-person marketing agency:
- 25 staff in office, 5 remote workers
- Handle client creative files (intellectual property)
- Store client contact information and contracts
- Use cloud tools (Google Workspace, Slack, Adobe Creative Cloud)
- Budget: $5,000 for new security measures
- Limited IT staff (1 part-time person)
```

Task - Develop a PROTECT Plan:

1. **Current State Assessment (20% of work)**

2. **Threat & Vulnerability Analysis (30%)**
3. **PROTECT Control Implementation (40%)**
4. **Implementation Plan (10%)**

Deliverable: 10-15 page report with threat analysis, recommended controls, timeline, budget, and metrics

---

Task 3: Incident Response Simulation (Advanced)

Objective: Experience real incident response process

Scenario:

```
Your company (200 employees) discovered:
- After-hours database access from Eastern Europe
- Unusual data export commands executed
- Employee reported phishing email
- Antivirus detected malware on IT manager's laptop
- Customer support receiving breach inquiry calls
```

Phases:

Phase 1: DETECT (Immediate) - Initial assessment - Incident classification - Initial response actions

Phase 2: RESPOND (Short-term) - Investigation & analysis - Containment actions - Communication & notifications

Phase 3: RECOVER (Medium-term) - System recovery - Operational recovery - Post-incident activities

Deliverables: - Written report (15-20 pages) OR - Live presentation (20-30 minutes) OR - Tabletop exercise (team-based)

Task 7: Self-Assessment Quiz (Beginner)

Part A: Foundational Knowledge (10 questions)

1. The NIST Cybersecurity Framework was first released in:
   - ☐ 2012
   - ☐ 2014
   - ☐ 2016
   - ☐ 2018
2. CSF 2.0 introduced which new function?

- ☐ Predict
- ☐ Govern
- ☐ Audit
- ☐ Monitor

3. Which function focuses on understanding current assets and risks?
    - ☐ Protect
    - ☐ Identify
    - ☐ Detect
    - ☐ Respond
4. The CSF is best described as:
    - ☐ Prescriptive set of rules
    - ☐ Framework with flexible outcomes
    - ☐ Technology-specific controls
    - ☐ Government mandate
5. NIST CSF is applicable to:
    - ☐ Only critical infrastructure
    - ☐ Only private companies
    - ☐ Any organization
    - ☐ Only government
6. Purpose of DETECT function:
    - ☐ Prevent incidents
    - ☐ Respond to incidents
    - ☐ Find and analyze activities
    - ☐ Recover systems
7. CSF Tiers measure:
    - ☐ Technical control strength
    - ☐ Governance maturity
    - ☐ Number of tools
    - ☐ Compliance status
8. A CSF Organizational Profile:
    - ☐ Describes current state only
    - ☐ Describes desired state only
    - ☐ Can describe both
    - ☐ Is not required
9. Which tier represents “Adaptive” approach?
    - ☐ Tier 1
    - ☐ Tier 2

- ☐ Tier 3
- ☐ Tier 4

10. GOVERN function primarily addresses:
    - ☐ Technical controls
    - ☐ Organizational strategy
    - ☐ Incident response
    - ☐ Employee training

---

9. References & Resources

Official NIST Resources

1. **NIST Cybersecurity Framework 2.0 (NIST CSWP 29)**
    - Full official document (February 26, 2024)
    - https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
2. **NIST CSF Website**
    - Main resource hub: https://www.nist.gov/cyberframework
    - Quick Start Guides
    - Community Profiles
    - Organizational Profile Templates
3. **NIST Quick Start Guides (QSGs)**
    - Tailored guidance by audience
    - CSF 2.0 Overview
    - Using Profiles and Tiers
    - Supply Chain Risk Management
    - Privacy Considerations

Related NIST Publications

4. **NIST SP 800-53** - Security and Privacy Controls
5. **NIST SP 800-39** - Risk Management Framework
6. **NIST SP 800-61** - Incident Handling Guide
7. **NIST SP 800-34** - Contingency Planning Guide

Related Standards & Frameworks

8. **ISO 27001** - Information Security Management
9. **COBIT 5** - IT Governance Framework
10. **ITIL v4** - Service Management
11. **CIS Controls** - Prioritized Controls

Learning Resources

12. **NIST CSF Online Courses** - Free training
13. **YouTube Tutorials** - Search "NIST CSF 2.0"

14. **Professional Certifications**
    - CISSP (Certified Information Systems Security Professional)
    - CISM (Certified Information Security Manager)
    - GSEC (GIAC Security Essentials)

Organizations & Resources

15. **CISA** - Cybersecurity and Infrastructure Security Agency
16. **SANS Institute** - Training and research
17. **(ISC)^2** - Certification provider
18. **EC-Council** - Cybersecurity training

Summary: Key Takeaways

1. **NIST CSF is foundational** - Most widely adopted globally
2. **CSF 2.0 adds governance** - New GOVERN function
3. **Framework, not rulebook** - Flexible application
4. **Six integrated functions** - All work together
5. **Profiles enable planning** - Current vs. Target states
6. **Tiers measure maturity** - Governance progression
7. **Supply chain matters** - CSF 2.0 emphasis
8. **Implementation varies** - Different per organization
9. **Continuous improvement** - Ongoing assessment
10. **Communication tool** - Common language across organization

---